ENGENHARIA DE SOFTWARE

Atividade de Direito Digital e Segurança

Plano de segurança da informação para instituição de ensino

Proposta acadêmica

Cenário com 2.500 alunos e três laboratórios de informática

Felipe Gomes Lima

Versão 1.0

Fortaleza CE
Novembro de 2026

Sumário

1 Apresentação da instituição 3

2 Objetivo do plano 3

3 Abrangência e levantamento do ambiente 3

4 Análise de riscos 4

5 Medidas de segurança 6

6 Backup e continuidade dos serviços 10

7 Resposta a incidentes 12

8 Responsabilidades 14

9 Implantação e acompanhamento 14

10 Referências 17

Anexo A Registro de ativos 18

Anexo B Registro de incidentes 19

Uso de inteligência artificial 20

Documento destinado ao planejamento da segurança no cenário proposto em sala. As metas operacionais, os prazos de implantação e as classificações de risco são propostas para validação. A existência de cada controle deverá ser confirmada em um levantamento técnico.

1 Apresentação da instituição

Este Plano de Segurança da Informação foi elaborado para o cenário de uma instituição de ensino com 2.500 alunos, além de professores e funcionários administrativos. Seu propósito é orientar a proteção dos recursos de informática e a continuidade das atividades acadêmicas e administrativas.

A instituição possui um data center próprio, instalado em suas dependências, caracterizando um ambiente on-premises. Nesse ambiente, há um servidor de arquivos destinado ao armazenamento e ao compartilhamento de documentos.

A infraestrutura também inclui três laboratórios de informática, com 30 computadores cada, totalizando 90 máquinas. Além dos laboratórios, a instituição utiliza desktops e notebooks em suas atividades. Possui ainda um site com hospedagem contratada de um fornecedor externo e um aplicativo, cuja forma de hospedagem não foi informada.

As quantidades de professores, funcionários administrativos e equipamentos fora dos laboratórios não foram especificadas. Esses dados, a capacidade dos servidores e as proteções existentes serão levantados antes da implantação. Os 90 computadores representam somente os laboratórios.

2 Objetivo do plano

Estabelecer medidas de segurança para proteger as informações, os equipamentos e os serviços de informática da instituição, reduzindo os riscos de acesso indevido, perda de dados e interrupção das atividades.

- **Confidencialidade:** permitir o acesso às informações somente a pessoas autorizadas, conforme suas funções e necessidades.
- **Integridade:** proteger os dados contra alterações ou exclusões indevidas e manter registro das modificações relevantes.
- **Disponibilidade:** manter informações e serviços acessíveis aos usuários autorizados, com procedimentos de recuperação diante de falhas.

Também são objetivos definir responsabilidades, orientar alunos, professores e funcionários sobre o uso seguro dos recursos tecnológicos e estabelecer procedimentos de prevenção, resposta a incidentes e recuperação.

3 Abrangência e levantamento do ambiente

O plano abrange pessoas, informações, equipamentos e serviços utilizados nas atividades institucionais. Aplica-se aos alunos, professores, funcionários administrativos e profissionais responsáveis pela TI, conforme os recursos e acessos utilizados por cada grupo.

Componente	Informação do cenário
Pessoas	2.500 alunos; professores e funcionários administrativos sem quantidade informada.
Data center e servidor de arquivos	Infraestrutura local própria e servidor destinado a documentos compartilhados.

Componente	Informação do cenário
Laboratórios	Três ambientes com 30 computadores cada, totalizando 90 máquinas.
Outros equipamentos	Desktops e notebooks utilizados nas demais atividades; quantidade a levantar.
Site	Hospedagem contratada de fornecedor externo.
Aplicativo	Aplicativo institucional; hospedagem, funcionalidades e dependências a levantar.

Serão identificados os dados cadastrais, registros acadêmicos, documentos administrativos e credenciais presentes em cada recurso. A estrutura da rede e das conexões, incluindo eventual Wi-Fi, também deverá ser mapeada. Esses elementos complementam o inventário e não representam uma configuração já confirmada.

Cada ativo deverá ter identificação, localização, finalidade, responsável, sistemas utilizados, dados envolvidos e importância para as atividades. Serviços externos devem ter fornecedor, contato de suporte, contrato e dependências registrados. O modelo do Anexo A orienta esse levantamento.

Para este exercício, propõe-se uma função de gestão de TI e uma função responsável pela proteção de dados. A direção deverá nomear os responsáveis e seus substitutos. Não se presume equipe de tamanho específico nem estrutura de atendimento já contratada.

4 Análise de riscos

A análise identifica situações que podem comprometer informações, equipamentos e serviços. A relação entre ameaças, fragilidades, probabilidade e impacto utiliza como referência conceitual o NIST SP 800-30 Rev. 1 [3]. A escala numérica abaixo é uma escolha didática deste plano.

Como o cenário não apresenta histórico de incidentes nem detalhes das proteções existentes, as classificações são estimativas para o exercício acadêmico. Deverão ser revistas após o levantamento técnico.

4.1 Critérios de avaliação

Valor	Probabilidade	Impacto
1 Baixo	Evento considerado pouco provável.	Prejuízo limitado, com pequena interferência nas atividades.
2 Médio	Evento possível, conforme exposição e proteção.	Interrupção de setor ou serviço e esforço de recuperação.
3 Alto	Evento considerado provável diante da exposição.	Exposição de dados pessoais, comprometimento de informações importantes ou interrupção significativa.

Pontuação de priorização = Probabilidade × Impacto. De 1 a 2 pontos: risco baixo. De 3 a 4 pontos: risco médio. De 6 a 9 pontos: risco alto. Não há resultado 5, 7 ou 8 nessa escala de multiplicação.

4.2 Riscos identificados

P representa probabilidade e I representa impacto. Cada código será utilizado para relacionar o risco às medidas propostas.

Código	Situação e consequência	P	I	Nível
R01	Roubo de senhas por páginas ou mensagens falsas, permitindo acesso indevido e exposição de informações.	3	3	Alto 9
R02	Programas maliciosos, incluindo ransomware, comprometem computadores e servidores, bloqueando, expondo ou destruindo arquivos.	2	3	Alto 6
R03	Falha de armazenamento ou exclusão acidental provoca perda de documentos e interrupção do trabalho.	2	3	Alto 6
R04	Permissões inadequadas permitem consultar, alterar ou excluir informações e acessar setores da rede sem autorização.	2	3	Alto 6
R05	Falta de energia ou superaquecimento paralisa o data center e pode danificar equipamentos.	2	3	Alto 6
R06	Falhas no site ou aplicativo permitem acesso indevido, alteração de conteúdo ou exposição de dados tratados pelo serviço.	2	3	Alto 6
R07	Indisponibilidade da hospedagem interrompe o site e os serviços que dependem do fornecedor.	2	2	Médio 4
R08	Furto ou perda de notebooks provoca prejuízo material e pode expor dados armazenados.	2	3	Alto 6

4.3 Validação e prioridades

A hipótese de maior probabilidade em R01 considera a quantidade de usuários expostos a mensagens e páginas falsas. Os demais eventos foram considerados possíveis, sem histórico disponível. Em R07, supôs-se que o site seja principalmente informativo; se sustentar matrícula, pagamentos ou outro serviço essencial, o impacto deverá ser elevado. Em R08, o impacto alto considera a possibilidade de dados pessoais no equipamento.

Devem ser verificadas senhas reutilizadas, permissões excessivas, sistemas desatualizados, backups não testados e falhas de separação das redes ou de proteção física. Nenhuma dessas fragilidades é considerada comprovada. O levantamento também deverá avaliar incêndio, alagamento, falha do link de internet e danos intencionais, incluindo novos riscos quando pertinente.

Riscos altos terão prioridade. Empates serão avaliados pela criticidade do serviço, pelos dados envolvidos e pela abrangência do impacto. Após os testes dos controles, a TI recalculará o risco residual, isto é, o risco que permanece. A direção registrará a aceitação temporária ou determinará medidas adicionais, com responsável e prazo.

5 Medidas de segurança

As medidas seguintes são propostas de implantação. Para cada ação, a TI deverá registrar execução, responsável, data e evidência de funcionamento. Prazos e parâmetros operacionais são metas deste plano, sujeitos à capacidade e à validação da instituição.

5.1 Contas e permissões de acesso

- Criar contas individuais e conceder somente os acessos necessários à função. O responsável pelo setor autoriza, a TI implementa e a revisão ocorre trimestralmente.
- Separar a conta de uso diário da conta administrativa. Acesso de fornecedores deve ser nominal, temporário e acompanhado. Contas de serviço terão responsável, finalidade e segredo protegido.
- Exigir autenticação multifator (MFA), que combina fatores de verificação, nas contas administrativas, no acesso remoto, na administração dos backups e nos serviços institucionais com suporte ao recurso. Priorizar métodos resistentes a páginas falsas, como chaves de segurança ou chaves de acesso (passkeys).
- Adotar senhas com pelo menos 15 caracteres, permitir gerenciadores e bloquear escolhas conhecidas como comuns ou comprometidas. Alterar senhas quando houver indício de comprometimento ou recuperação de conta; não impor troca periódica sem motivo [4].
- Desativar acessos e revogar sessões no desligamento comunicado pelo setor responsável. Para alunos, ajustar o acesso ao término do vínculo preservando as obrigações de guarda documental.
- Bloquear a tela após 10 minutos de inatividade. Recuperação de contas exige verificação de identidade; a equipe não deve solicitar a senha atual do usuário.

5.2 Computadores e laboratórios

Os 90 computadores dos laboratórios deverão ter configuração padronizada, proteção contra programas maliciosos, atualizações gerenciadas e contas de estudante sem administração do sistema. Atividades que exijam privilégios elevados deverão usar ambientes de ensino isolados, sob supervisão do professor.

Desktops e notebooks institucionais devem integrar o inventário. A TI habilitará criptografia de disco nos equipamentos que armazenem informações restritas, guardará as chaves de recuperação em local protegido e verificará se os sistemas ainda recebem suporte. Documentos de trabalho devem ser mantidos nos repositórios institucionais previstos no backup.

Como metas iniciais, vulnerabilidades críticas exploradas em ataques terão avaliação e contenção imediatas, com correção em até 48 horas após disponibilidade e validação da atualização. Outras falhas de alta gravidade terão meta de 7 dias; atualizações de rotina, 30 dias. Impedimentos exigem proteção compensatória, responsável e prazo de revisão.

Instalações serão autorizadas pela TI. Mídias removíveis serão restringidas conforme a atividade, com verificação de arquivos. Ao final do uso compartilhado, o usuário deve encerrar a sessão e remover seus arquivos temporários. A imagem de recuperação do laboratório será atualizada após mudanças aprovadas.

5.3 Rede e acesso remoto

Propõe-se separar os ambientes em segmentos e aplicar regras por firewall, que controla o tráfego entre redes, ou mecanismo equivalente. A separação por redes locais virtuais (VLANs) deve ser acompanhada de regras de acesso verificadas; permitir apenas o tráfego necessário.

Segmento proposto	Acesso permitido
Administrativo	Sistemas e pastas necessários a cada setor; acesso conforme função.
Laboratórios e alunos	Internet e serviços educacionais autorizados; sem acesso direto à administração dos servidores.
Visitantes e dispositivos pessoais	Internet, sem acesso à rede interna; isolamento entre usuários quando viável.
Servidores e gestão de TI	Comunicações de serviço documentadas; administração apenas por equipamentos e contas autorizados.

O servidor de arquivos não deverá ser exposto diretamente à internet. O acesso remoto administrativo usará conexão protegida e MFA. A TI manterá configurações dos equipamentos de rede em backup, registrará mudanças e testará as restrições usando contas de cada perfil. Redes sem fio, se existentes, seguirão a mesma separação.

5.4 Proteção física e ambiental

O data center terá acesso restrito a pessoas autorizadas e visitantes acompanhados, com registro de entradas. Racks, cabos e equipamentos devem ser identificados. A manutenção predial e a TI avaliarão climatização, sensores e alertas de temperatura, proteção elétrica e nobreak dimensionado para a carga e para desligamento seguro.

A inspeção deverá incluir risco de água, detecção de incêndio e procedimentos de emergência definidos com profissionais habilitados. A segurança das pessoas terá prioridade. Nobreak não será tratado como garantia de operação prolongada; a autonomia será medida e a necessidade de geração alternativa será avaliada.

Notebooks terão termo de responsabilidade, controle de retirada e devolução e comunicação imediata de perda. Antes do descarte ou transferência de equipamentos, a TI deverá sanitizar os dados e registrar a destinação.

5.5 Arquivos e classificação da informação

As pastas compartilhadas serão organizadas por setor e finalidade, evitando permissões gerais de leitura ou escrita. O responsável pelo conteúdo autorizará os acessos. A TI habilitará registros de alterações relevantes, versionamento quando disponível e testes trimestrais de acesso com perfis distintos.

Classe proposta	Exemplos e tratamento
Pública	Informações aprovadas para divulgação, como calendário público e notícias institucionais.
Interna	Procedimentos e materiais de trabalho destinados à comunidade autorizada.
Restrita	Cadastros, registros acadêmicos, documentos financeiros e dados sensíveis quando existentes. Acesso por necessidade e compartilhamento controlado.

Documentos restritos serão compartilhados por canais institucionais protegidos, com destinatário verificado e prazo de acesso quando cabível. Senhas, chaves e tokens não devem ficar em planilhas abertas, mensagens coletivas ou código-fonte.

5.6 Segurança do site e do aplicativo

A TI deverá mapear o aplicativo, suas integrações e eventuais bancos de dados. Antes de cada publicação relevante, a equipe responsável verificará autenticação, autorização no servidor, tratamento de entradas e arquivos enviados, dependências, configuração e registros de segurança. O OWASP Top 10 será referência de verificação [7].

As comunicações deverão usar HTTPS com certificados válidos. A renovação será monitorada. Painéis administrativos terão MFA, acessos individuais e restritos; segredos serão armazenados fora do código. Dados reais de alunos deverão ser evitados nos ambientes de desenvolvimento e teste, preferindo dados fictícios.

A publicação exigirá cópia recuperável da versão anterior, registro da mudança e procedimento para voltar à versão estável. Testes de segurança terão escopo autorizado e ambiente controlado. Falhas críticas com possibilidade de exploração deverão ser corrigidas ou contidas antes da liberação. A equipe verificará também as permissões solicitadas pelo aplicativo nos dispositivos.

5.7 Serviços contratados e fornecedores

O contrato de hospedagem deverá esclarecer disponibilidade, suporte, atualizações, backups, restauração, acesso aos registros e comunicação de incidentes. A instituição confirmará quais controles estão incluídos e quais precisam ser executados por sua equipe. Terceirizar a hospedagem não elimina a necessidade de acompanhar o serviço.

Propõe-se notificação contratual à instituição em até 2 horas após o fornecedor identificar incidente potencialmente relacionado aos seus dados ou serviços, com atualizações enquanto houver impacto. Essa é uma meta contratual proposta. O contrato deve prever exportação e devolução dos dados, encerramento dos acessos e destinação das cópias ao término do serviço.

A TI validará periodicamente uma restauração, inclusive para dados mantidos por terceiros. Créditos financeiros por indisponibilidade não substituem a recuperação do serviço. As metas da seção 6 deverão ser negociadas e demonstradas pelo fornecedor.

5.8 Monitoramento e registros

A TI centralizará, conforme a capacidade disponível, registros de autenticação, mudanças de privilégios, alertas de proteção, acessos administrativos, backups e disponibilidade. Relógios dos sistemas devem estar sincronizados. Alertas de múltiplas falhas de login, alterações em massa e falha de backup serão encaminhados ao responsável e ao substituto.

Propõe-se manter registros operacionais por 180 dias, sendo pelo menos 30 dias disponíveis para consulta rápida. O prazo será ajustado às finalidades, obrigações aplicáveis e capacidade. Evidências de incidentes terão guarda própria. Logs serão protegidos contra alteração e acesso indevido e não deverão conter senhas nem dados pessoais desnecessários.

Durante o funcionamento da instituição, a TI verificará diariamente alertas e tarefas de backup. Alertas críticos fora desse horário dependerão de plantão ou suporte contratado a ser definido no cronograma. A direção deverá conhecer qualquer período sem cobertura.

5.9 Orientação e uso aceitável

Alunos receberão orientações no início do semestre e antes de utilizar os laboratórios. Professores e funcionários participarão de orientação na admissão e de revisão semestral. Os temas incluem mensagens falsas, proteção de contas, compartilhamento de arquivos, uso de dispositivos e comunicação de problemas.

A instituição divulgará regras de uso dos equipamentos e um canal de suporte. Serão vedados compartilhamento de contas, desativação das proteções e instalação não autorizada de programas. Testes práticos de segurança em aula deverão ocorrer em ambiente autorizado e isolado. A presença nas orientações e as dúvidas recorrentes serão registradas, sem exposição individual desnecessária.

5.10 Proteção de dados pessoais

A LGPD orienta a adoção de medidas técnicas e administrativas de proteção. Para as atividades em que decide a finalidade e os meios de tratamento, a instituição atua como controladora. Um fornecedor será operador quando tratar dados em seu nome, conforme a atividade realizada [1].

Cada setor deverá registrar a finalidade, os dados necessários, a base legal aplicável, os destinatários e o prazo de conservação. Consentimento não será presumido como base de todo tratamento. A instituição disponibilizará informação clara e canal para solicitações dos titulares, com verificação de identidade e encaminhamento ao responsável pela proteção de dados.

Dados sensíveis, como informações de saúde eventualmente recebidas, terão acesso especialmente restrito. Se houver crianças ou adolescentes, será observado seu melhor interesse e as regras aplicáveis. A tabela de temporalidade considerará obrigações acadêmicas e legais; eliminações ocorrerão de modo seguro quando cabíveis. A política de backup não define o prazo legal de guarda dos documentos [1].

5.11 Relação entre riscos e controles

Risco	Controles principais	Evidência de verificação
R01	MFA, contas individuais e orientação.	Teste de MFA e registro de orientação.
R02	Proteção dos equipamentos, correções e isolamento.	Alertas revisados e teste seguro de contenção.
R03	Backups, versionamento e recuperação.	Relatório de restauração com tempo medido.
R04	Permissões por função e separação das redes.	Teste de acesso permitido e acesso bloqueado.
R05	Controle físico, climatização e proteção elétrica.	Inspeção e teste acompanhado do desligamento.
R06	Verificação das aplicações e gestão de mudanças.	Relatório de teste e correções registradas.
R07	Contrato, monitoramento e recuperação alternativa.	Registro de atendimento e teste com fornecedor.
R08	Criptografia, inventário e controle de retirada.	Conferência da criptografia e termo de responsabilidade.

6 Backup e continuidade dos serviços

6.1 Dados e cópias de segurança

A política abrangerá os arquivos institucionais, as configurações dos serviços e da rede, o conteúdo do site e os dados e configurações do aplicativo, incluindo banco de dados se existente. Arquivos de trabalho não deverão depender de uma única estação. A TI e os responsáveis pelos setores definirão quais pastas e sistemas integram cada tarefa. Bancos de dados exigem cópias consistentes, produzidas por mecanismos adequados à aplicação e validadas na restauração.

Propõe-se manter três cópias, incluindo os dados de produção, em armazenamentos independentes, com pelo menos uma cópia externa protegida contra alteração ou desconectada. Cópias acessíveis com as mesmas credenciais do ambiente principal não serão consideradas proteção suficiente contra comprometimento dessas contas. Backups devem ser protegidos, verificados e testados [5].

Conjunto	Frequência proposta	Retenção inicial
Arquivos críticos e dados do aplicativo	Ponto recuperável a cada 4 horas, incluindo cópia externa protegida.	Pontos de 4 horas por 7 dias; um diário por 30 dias; um mensal por 90 dias.
Conteúdo e configuração do site	Diário e antes de publicação relevante.	30 dias de pontos diários e versão anterior à publicação.
Configurações de rede e imagens dos laboratórios	Semanal e após mudança aprovada.	Últimas 4 versões semanais e a última configuração estável.

As retenções acima são propostas operacionais, a ajustar à classificação e à temporalidade dos documentos. A solução deve manter a cadeia completa necessária a cada restauração. Na cópia externa dos dados críticos, o intervalo de 4 horas deve ser efetivamente cumprido; uma cópia externa apenas semanal não atende a essa meta.

As cópias serão criptografadas e administradas por contas específicas com MFA, quando suportado. As chaves de recuperação ficarão disponíveis a responsáveis autorizados em local separado e seguro. Falhas de tarefas gerarão alerta e repetição controlada. Sincronização de pastas e snapshots no mesmo equipamento não serão tratados como única estratégia de backup.

6.2 Metas de recuperação

RPO é o limite proposto de perda de dados recentes, medido em tempo. **RTO** é o tempo proposto entre a indisponibilidade e a retomada do serviço. As metas a seguir usam horas corridas, dependem de testes e deverão ser aprovadas após a avaliação do impacto nas atividades.

Serviço	RPO proposto	RTO proposto
Servidor de arquivos críticos	4 horas	8 horas
Aplicativo e seus dados	4 horas	8 horas
Site institucional	24 horas	24 horas
Computadores dos laboratórios	Configuração semanal e após mudanças; trabalhos salvos no repositório institucional.	Primeiro laboratório em até 24 horas; demais em até 48 horas.

As metas do aplicativo são provisórias até que suas funções sejam conhecidas. A recuperação precisa incluir energia, rede, autenticação e demais dependências dentro do RTO, e não somente a restauração de arquivos. Se não houver equipamento substituto ou capacidade contratada, a direção deverá financiar a alternativa ou revisar formalmente a meta.

6.3 Testes e continuidade das atividades

A TI fará teste mensal de restauração de uma amostra e teste trimestral de recuperação de um serviço completo em ambiente isolado. O resultado registrará ponto recuperado, integridade, permissões e duração. O responsável pelo setor validará o uso dos dados. Após restauração, deverão ser reaplicadas exclusões autorizadas e restrições que tenham ocorrido depois do ponto recuperado.

Em indisponibilidade, a direção e a coordenação acadêmica organizarão a continuidade: remanejamento de aulas práticas, uso de materiais previamente aprovados e atendimento temporário com coleta mínima de dados. Registros provisórios terão guarda restrita e posterior conferência antes de inserção nos sistemas.

A ordem inicial de recuperação será: segurança física e energia; rede e autenticação; arquivos críticos e aplicativo; site; demais estações e laboratórios. A ordem poderá mudar conforme o impacto real. Comunicações sobre indisponibilidade usarão canal institucional alternativo previamente definido e independente do serviço afetado.

7 Resposta a incidentes

7.1 Acionamento e classificação

Qualquer usuário deverá informar suspeitas de invasão, perda de equipamento, arquivo inacessível ou exposição de dados à TI. A direção divulgará um canal principal e um telefone alternativo antes da implantação. A TI manterá a lista de contatos do responsável, substituto, direção, proteção de dados, manutenção e fornecedores, com cópia disponível fora dos sistemas críticos.

Gravidade	Exemplo	Meta interna de triagem
Crítica	Ransomware ativo, exposição relevante de dados ou paralisação ampla.	Até 30 minutos após detecção; acionar direção e responsável por dados imediatamente.
Alta	Conta privilegiada comprometida ou serviço importante indisponível.	Até 2 horas após detecção.
Moderada	Falha localizada, contida e sem evidência inicial de exposição de dados.	Até 1 dia útil; elevar a gravidade se surgirem novos indícios.

Essas metas de atendimento são propostas internas e exigem cobertura compatível. Não substituem os prazos de comunicação previstos na legislação.

7.2 Procedimento de resposta

- **Registrar e avaliar:** a TI abre o registro do incidente, identifica horário, origem do alerta, serviços e pessoas afetados e verifica se há dados pessoais envolvidos.
- **Conter:** a TI isola equipamentos ou contas comprometidos, restringe compartilhamentos e protege as cópias de segurança, registrando as decisões tomadas.
- **Preservar evidências:** conservar registros, mensagens e arquivos relevantes em repositório restrito. Documentar quem coletou, quando coletou e cada acesso às evidências; preservar originais e verificar integridade quando possível.
- **Corrigir a causa:** remover acessos indevidos, corrigir a falha explorada e reconstruir sistemas a partir de fontes confiáveis quando necessário.
- **Recuperar e validar:** restaurar dados confiáveis, testar funcionamento e permissões com o setor responsável e autorizar a reconexão somente após validação.

- **Comunicar e melhorar:** a direção coordena os avisos; o responsável pela proteção de dados avalia as obrigações legais. Em até 5 dias úteis após estabilização, a TI entrega relatório e ações de melhoria.

O procedimento adapta ao cenário as atividades de detecção, resposta e recuperação descritas pelo NIST SP 800-61 Rev. 3 [6]. A contenção urgente deve ser compatibilizada com a preservação das evidências e com a continuidade de serviços essenciais.

7.3 Aplicação em situações comuns

Computador com suspeita de ransomware: interromper o uso e avisar a TI; desconectar da rede, quando seguro, para limitar a propagação. Não formatar nem restaurar por iniciativa própria. A TI avalia preservação de evidências, extensão do comprometimento e necessidade de desligamento antes de reconstruir o ambiente [9].

Conta comprometida: bloquear temporariamente a conta, revogar sessões, redefinir credenciais por canal seguro, revisar MFA e verificar alterações ou acessos realizados. O retorno ao uso depende da análise da TI.

Notebook perdido ou furtado: comunicar imediatamente à TI e à direção; revogar sessões e avaliar os dados, a criptografia e os registros de acesso. A direção define as providências cabíveis, incluindo registro policial quando pertinente. Eventual bloqueio ou apagamento remoto depende de ferramenta disponível e avaliação das evidências.

Site ou aplicativo indisponível: verificar alcance e causa, acionar o fornecedor, registrar o atendimento e divulgar orientação pelo canal alternativo. Uma restauração ou retorno de versão só ocorrerá após avaliar integridade e risco de repetição do problema.

7.4 Incidentes com dados pessoais

O responsável pela proteção de dados e a direção avaliarão se o incidente pode acarretar risco ou dano relevante aos titulares, conforme os critérios da Resolução CD/ANPD nº 15/2024. A classificação técnica de risco deste plano não substitui essa avaliação jurídica [2].

Quando a comunicação for obrigatória, a instituição, como controladora, deverá comunicar a ANPD e os titulares em regra em até 3 dias úteis, contados do conhecimento de que o incidente afetou dados pessoais, observadas regras específicas aplicáveis. Informações podem ser complementadas de forma fundamentada em até 20 dias úteis após a comunicação. O operador deve informar o controlador sem demora injustificada [2, 8].

Os registros de incidentes envolvendo dados pessoais serão conservados, em regra, por pelo menos 5 anos, inclusive quando não houver comunicação externa, com justificativa registrada. A direção verificará eventuais regras próprias de guarda pública e enquadramento em regimes específicos; o número de alunos não comprova pequeno porte [2].

A instituição manterá evidências das comunicações e das decisões. O modelo do Anexo B organizará os dados do incidente; os formulários oficiais vigentes deverão ser utilizados quando exigidos.

8 Responsabilidades

A direção deverá nomear um titular e um substituto para cada função operacional. Uma pessoa poderá acumular atividades quando necessário, mas aprovações sensíveis e verificações deverão ter revisão por outra pessoa sempre que possível.

Função	Responsabilidades
Direção	Aprovar o plano e os recursos; resolver prioridades; decidir sobre continuidade e aceitação de riscos; coordenar comunicação institucional.
Gestão de TI	Manter inventário e matriz de riscos; implantar controles; acompanhar indicadores; coordenar incidentes e recuperação.
Equipe ou suporte de TI	Executar atualizações, gestão de contas, backups, monitoramento e testes; registrar evidências e escalar falhas.
Gestores dos setores e coordenação acadêmica	Autorizar acessos; classificar dados; definir necessidades de continuidade; validar dados e serviços recuperados.
Responsável pela proteção de dados	Orientar o tratamento de dados e as solicitações dos titulares; apoiar a avaliação de incidentes e a comunicação em nome da instituição.
Manutenção e segurança patrimonial	Inspecionar energia, climatização e acesso físico; acompanhar emergências e manutenção especializada.
Alunos, professores e funcionários	Cumprir as regras, proteger credenciais, utilizar canais autorizados e relatar incidentes.
Fornecedores	Executar obrigações contratadas, cooperar com testes e investigações e informar falhas ou incidentes.

A TI produz evidências técnicas; o gestor do setor valida a necessidade do acesso; a direção aprova recursos e exceções. O responsável pela proteção de dados assessora a avaliação legal, sem assumir sozinho todas as obrigações da instituição.

9 Implantação e acompanhamento

9.1 Cronograma proposto

O cronograma inicia na aprovação do plano e utiliza dias corridos. As ações iniciais de proteção de contas e recuperação podem ocorrer em paralelo ao inventário. Nenhuma medida será considerada concluída apenas pela aquisição de uma ferramenta.

Prazo	Entregas prioritárias	Responsável principal
Dias 1 a 15	Nomear responsáveis; levantar ativos e serviços críticos; definir contatos; revisar administradores; habilitar MFA prioritário; verificar uma restauração de backup.	Direção e TI
Dias 16 a 30	Corrigir exposições prioritárias; configurar rotinas de backup; revisar permissões; proteger notebooks; avaliar data center e requisitos contratuais.	TI, gestores e manutenção
Dias 31 a 60	Implantar e testar separação das redes; padronizar laboratórios; centralizar alertas; avaliar site e aplicativo; orientar usuários; registrar tratamentos e temporalidade.	TI, setores e proteção de dados
Dias 61 a 90	Executar simulado de incidente e recuperação completa; medir RTO e RPO; corrigir pendências; revisar riscos residuais e aprovar o início da rotina.	TI e direção

9.2 Recursos e critérios de conclusão

O orçamento deverá considerar horas da equipe, capacitação, armazenamento de backups, proteção dos equipamentos, capacidade de rede, ajustes elétricos e de climatização e suporte contratado. Os valores dependerão do inventário e de cotações; não há orçamento informado no cenário. Recursos existentes poderão ser utilizados após verificação de capacidade e suporte.

Cada entrega será validada por evidência: MFA funcionando; acesso indevido bloqueado; equipamento inventariado; backup restaurado; alerta recebido; responsável acionado; serviço recuperado dentro da meta. Pendências terão responsável, prazo, medida temporária e decisão da direção. Uma meta de recuperação que falhar no teste deverá ser revista ou acompanhada de investimento para torná-la viável.

9.3 Indicadores e verificações

Indicador ou teste	Meta proposta	Frequência
Ativos identificados	100% dos ativos identificados no levantamento cadastrados; 90 computadores de laboratório conferidos.	Mensal e após aquisições
Contas administrativas com MFA	100% onde suportado; exceções formalizadas com proteção compensatória.	Mensal
Backups concluídos	Pelo menos 98% das tarefas no mês; toda falha analisada e tratada.	Conferência diária
Restauração	Uma amostra validada por mês e um serviço completo por trimestre, medindo RPO e RTO.	Mensal e trimestral
Atualizações de segurança	100% das falhas críticas dentro da meta ou com exceção aprovada e contenção.	Semanal

Indicador ou teste	Meta proposta	Frequência
Permissões de acesso	Todos os setores revisados; contas desligadas conferidas.	Trimestral
Treinamento de funcionários e professores	100% convocados e pelo menos 95% de participação; reposição para ausentes.	Semestral
Simulado de incidente	Pelo menos um exercício de acionamento e recuperação documentado.	Semestral

A taxa de conclusão de backup é calculada dividindo tarefas concluídas com sucesso pelas tarefas previstas. Ela não demonstra, sozinha, que os dados podem ser restaurados: os testes de recuperação são obrigatórios para validar essa capacidade.

9.4 Revisão do plano

A TI apresentará acompanhamento mensal à direção. O plano será revisado semestralmente e após incidente relevante, mudança importante de infraestrutura, contratação de serviço ou alteração normativa aplicável. Cada revisão registrará versão, data, responsável e alterações.

Exceções deverão indicar risco, justificativa, controle compensatório, responsável e data de vencimento, com reavaliação em até 90 dias. A aceitação de risco não dispensa obrigações legais. O próximo ciclo será definido a partir das pendências, dos resultados dos testes e das mudanças no ambiente.

10 Referências

Fontes consultadas em 3 de novembro de 2026. As referências fundamentam os princípios e procedimentos; as pontuações, os prazos internos, as retenções de backup e o cronograma são propostas deste plano.

[1] BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais. Texto atualizado. Texto da LGPD

[2] ANPD. Resolução CD/ANPD nº 15, de 24 de abril de 2024. Regulamento de Comunicação de Incidente de Segurança. Regulamento de comunicação de incidentes

[3] NIST. SP 800-30 Rev. 1. Guide for Conducting Risk Assessments. 2012. Guia de avaliação de riscos

[4] NIST. SP 800-63B-4. Digital Identity Guidelines Authentication and Authenticator Management. 2025. Orientações sobre autenticação

[5] CISA et al. StopRansomware Guide. 2023. Guia de prevenção e recuperação de ransomware

[6] NIST. SP 800-61 Rev. 3. Incident Response Recommendations and Considerations for Cybersecurity Risk Management. 2025. Guia de resposta a incidentes

[7] OWASP FOUNDATION. OWASP Top 10 2025. Riscos de segurança em aplicações web

[8] ANPD. Comunicação de Incidente de Segurança. Página de orientações, atualizada em 26 de agosto de 2026. Procedimentos e perguntas frequentes

[9] CERT.br. Ransomware Como Responder. Versão 1.1, 5 de outubro de 2025. Orientações de resposta a ransomware

Anexo A Registro de ativos

Preencher uma ficha por equipamento, sistema ou serviço. O código LAB01-PC01 pode identificar o primeiro computador do laboratório 1; trata-se apenas de um exemplo de identificação.

Identificação
Código do ativo, tipo, descrição e patrimônio quando aplicável.

Localização e vínculo
Setor, sala ou provedor; proprietário institucional e responsável pelo uso.

Configuração
Sistema e versão, suporte, capacidade e endereço de rede quando aplicável.

Informações tratadas
Finalidade, categorias de dados, classificação e responsável pelo conteúdo.

Acessos e dependências
Perfis autorizados, integrações, energia, rede, autenticação e outros serviços.

Proteções verificadas
Atualização, proteção contra malware, criptografia, backup e evidências.

Continuidade
Criticidade, RPO, RTO, procedimento de recuperação e último teste.

Controle
Data da conferência, responsável pela verificação, pendências e prazo de correção.

Anexo B Registro de incidentes

Usar um registro por incidente. Restringir o acesso e registrar as atualizações em ordem cronológica. Este modelo auxilia o registro interno e não substitui formulário oficial de comunicação.

Identificação e tempos
Código, origem do alerta, ocorrência estimada, detecção e ciência de dados pessoais afetados.

Escopo e impacto
Sistemas, equipamentos, categorias de dados, titulares afetados ou estimativa e consequências.

Avaliação
Gravidade técnica, risco aos titulares, hipótese da causa e fatos já confirmados.

Ações e evidências
Contenção, correções, responsáveis, horários, localização e integridade das evidências.

Comunicações
Quem foi informado, conteúdo, canal, data, protocolo e justificativa de eventual não comunicação.

Recuperação
Ponto restaurado, validação pelo setor, tempo de indisponibilidade e autorização de retorno.

Encerramento
Causa identificada, melhorias, responsáveis, prazos e data de revisão.

Guarda
Responsável pelo registro, pessoas autorizadas, prazo aplicável e localização protegida.

Uso de inteligência artificial

Usei o ChatGPT pra me ajudar a entender o exemplo passado pelo professor, organizar as partes e escrever o plano de segurança. Depois, pedi pra juntar tudo em um documento.

Resumo dos pedidos que fiz durante a conversa:

Chat, vamos fazer um plano de segurança pra um exemplo que o professor de Direito Digital e Segurança passou. Só que eu ainda não entendi direito como fazer, então vou passar o cenário pra você me ajudar.

É uma instituição de ensino que tem:

- 2.500 alunos, professores e funcionários administrativos.
- Um data center dentro da instituição, com servidor de arquivos.
- Um site com hospedagem contratada e um aplicativo.
- Três laboratórios de informática, com 30 computadores em cada.
- Outros computadores e notebooks.

Quero que você me explique como seria esse plano e me ajude a montar passo por passo, pra eu entender o que colocar em cada parte. Depois, junte tudo em um documento.